

# Cirque Corporation

## Data Classification Policy

**Document ID:** IS-CIRQ-P-026-G

**Category:** Information Management Regulations

**Division:** Policy

**Type:** Global

**Version:** 1.0

**Effective Date:** 2026-03-02

**Review Date:** 2027-03-02

**Approved By:** Executive Committee

**Generated:** March 02, 2026

### 1. Purpose

The purpose of this policy is to establish a standardized data classification framework that enables Cirque to identify, categorize, and protect information assets based on their sensitivity, criticality, and regulatory requirements. This policy ensures that appropriate safeguards are applied to data throughout its lifecycle, in accordance with ISO/IEC 27001:2022 Annex A.8.2, SOC2:2022 criteria, and applicable data protection regulations (GDPR, CCPA, etc.).

**\*\*2. Scope\*\***

### 2. Scope

This policy applies to all information and data owned, processed, or stored by Cirque, regardless of format (electronic, physical, verbal), location (on-premises, cloud, personal devices), or whether the data is owned by Cirque or belongs to customers, partners, or other third parties. This includes:

- Customer data and personal information
- Intellectual property (CAD drawings, firmware, software code, ASIC designs)
- Financial records and accounting information
- Employee and contractor information
- Project management data (Asana, GitLab)
- Communications (email, chat, documentation)
- System configurations and security information
- Backup and archive data

All employees, contractors, consultants, and third parties who access Cirque data are required to comply with this policy.

### **\*\*3. Data Classification Levels\*\***

## **3. Data Classification Levels**

Cirque uses a four-tier data classification framework:

### **\*\*3.1. Confidential (Red/High Risk)\*\***

**\*\*Definition:\*\*** Data that, if disclosed, would cause severe damage to Cirque's business, legal standing, competitive position, or to customers/partners. Unauthorized access is strictly prohibited.

#### **\*\*Examples:\*\***

- Customer proprietary data and trade secrets
- Financial data: budgets, financial statements, pricing strategies
- Employee personal information (SSN, salary, medical records)
- Intellectual property: ASIC designs, firmware source code, CAD drawings, firmware architecture documentation
- Active security vulnerabilities, attack vectors, penetration test results
- Executive strategic plans and merger/acquisition information
- Encryption keys and cryptographic material

- Authentication credentials and tokens

**\*\*Handling Requirements:\*\***

- Access strictly limited to authorized personnel with explicit business need
- Data must be encrypted at rest (AES-256 or stronger) and in transit (TLS 1.2+)
- Storage in approved secure repositories only (encrypted cloud storage, on-premises secure database)
- No storage on unencrypted personal devices; must use managed endpoints with MDM
- Deletion: Upon termination of use or per legal hold requirements (minimum retention specified by business function)
- Transfer: Only via secure, encrypted channels (encrypted email, VPN, secure file transfer)
- Logging: All access must be logged and monitored; unusual access patterns flagged for review
- Approval: IT Manager and data owner approval required before access or sharing
- Contractor/third-party access: Explicit data processing agreements (DPA) required with confidentiality obligations

**\*\*3.2. Restricted (Yellow/Medium Risk)\*\***

**\*\*Definition:\*\*** Data that is sensitive and requires protection but is less critical than Confidential data. Disclosure could cause moderate harm or regulatory concern.

**\*\*Examples:\*\***

- Customer contact information (name, email, phone)
- Internal project plans and schedules
- Employee directory information

- Operational procedures and runbooks (non-security)
- Vendor contracts and pricing
- Legal correspondence and advice
- Internal performance metrics and KPIs
- Quality assurance test data (non-customer data)
- Log data containing user activity patterns

**\*\*Handling Requirements:\*\***

- Access limited to employees with legitimate business need; stored in role-based environments
- Data encryption recommended at rest; required in transit
- Storage in approved corporate repositories (shared drives, cloud storage with access controls, managed databases)
- May be stored on managed corporate devices only (never on personal devices or unmanaged endpoints)
- Deletion: Per data retention policy (typically 3-7 years depending on function)
- Transfer: Via secure channels (encrypted email, VPN, secure file transfer); internal sharing requires minimal access controls
- Logging: Access logging recommended for compliance and audit
- Approval: Data owner approval generally required; IT approval for sharing outside immediate team
- Contractor/third-party access: Data processing agreements (DPA) required with standard confidentiality terms

**\*\*3.3. Internal (Green/Low Risk)\*\***

**\*\*Definition:\*\*** Data intended for internal use only but not particularly sensitive. Disclosure would cause minimal harm.

**\*\*Examples:\*\***

- Internal announcements and company news

- Organization charts and team structures
- Public-facing website content and marketing materials
- General meeting minutes and memos (non-confidential)
- Internal training materials and documentation
- Published corporate policies and procedures
- General audit logs and system performance data
- Non-sensitive operational information

**\*\*Handling Requirements:\*\***

- Access available to all employees; no special access controls required
- Encryption: Not required but recommended for data in transit
- Storage: Internal repositories, shared drives, corporate websites
- May be stored on company devices; personal device storage permitted if encrypted
- Deletion: Per business needs; no strict retention requirement
- Transfer: Via standard internal communication channels
- Logging: Optional
- Approval: Not required
- Contractor/third-party access: Generally permitted with standard confidentiality terms

**\*\*3.4. Public (Blue/Minimal Risk)\*\***

**\*\*Definition:\*\*** Data that is intentionally released for public distribution. Disclosure causes no harm.

**\*\*Examples:\*\***

- Published marketing content and brochures
- Publicly released press releases and announcements
- Job postings and career information
- Published research and technical whitepaper abstracts

- General company contact information (main phone, corporate address)
- Product documentation (non-proprietary)
- Social media content

**\*\*Handling Requirements:\*\***

- No access restrictions
- Encryption: Not required
- Storage: Anywhere
- Deletion: Not required; can remain in archives
- Transfer: Unrestricted
- Logging: Not required
- Approval: Not required for external sharing
- Contractor/third-party access: No restrictions

**\*\*4. Data Classification Process\*\***

## **4. Data Classification Process**

**\*\*4.1. Classification Responsibility\*\***

Data owners are responsible for:

- Classifying data within their domain of responsibility
- Documenting classification rationale
- Communicating classification to relevant stakeholders (custodians, users)
- Periodically reviewing and updating classification (at least annually)
- Escalating ambiguous classifications to IT Manager + Compliance

**\*\*4.2. Classification Criteria\*\***

When classifying data, consider:

- **\*\*Legal/Regulatory Requirements:\*\*** Does the data fall under GDPR, HIPAA, SOC2, CCPA, or other compliance frameworks?

- **Business Value:** What is the competitive or strategic value of this data?
- **Sensitivity:** How sensitive is this data? Who could be harmed by disclosure?
- **Criticality:** How critical is this data to business operations?
- **Stakeholder Impact:** Would disclosure harm Cirque, customers, employees, or partners?

#### **4.3. Data Tagging and Labeling**

- **Electronic Data:** Metadata tags (sensitivity labels in Microsoft 365, classification fields in databases)
- **Physical Documents:** Red, Yellow, Green, or Blue labels on headers/footers
- **Containers & Systems:** Labels on storage containers, file shares, databases indicating highest classification level contained

#### **4.4. Exceptions & Re-Classification**

- Regular business review may warrant re-classification to lower category (e.g., Confidential → Restricted after time has passed)
- Re-classification to higher category requires IT Manager and data owner approval
- Documented exceptions require Executive Committee approval

#### **5. Data Handling Standards by Classification**

### **5. Data Handling Standards by Classification**

| Requirement           | Confidential             | Restricted                   | Internal      | Public       |
|-----------------------|--------------------------|------------------------------|---------------|--------------|
| Access Control        | Need-to-know, Role-based | Role-based, Department-based | All employees | Unrestricted |
| Encryption at Rest    | Required (AES-256+)      | Recommended                  | Optional      | Not required |
| Encryption in Transit | Required (TLS 1.2+)      | Required                     | Recommended   | Optional     |

| **Approval for Access** | IT Manager + Owner | Owner | None | None |  
| **Device Storage** | Managed only | Managed only | Company or managed | Any |  
| **Retention** | Per legal hold (7y+) | Business need (3-7y) | Business need | Indefinite |  
| **Transfer Method** | Encrypted channels only | Encrypted channels | Standard channels | Unrestricted |  
| **Access Logging** | Mandatory + monitored | Recommended | Optional | Not required |  
| **DPA Required** | Yes | Yes | No | No |  
| **Third-Party Access** | Explicit agreements | Standard terms | Permitted | Permitted |

## **6. Data Lifecycle Management**

### **6. Data Lifecycle Management**

#### **6.1. Data Creation & Acquisition**

- Data owners shall identify and classify data upon creation or acquisition
- Classification metadata shall be embedded in systems/documents
- Approval required before collecting customer/personal data

#### **6.2. Data Use & Processing**

- Data shall be handled according to its classification level
- Access granted on need-to-know basis with role-based controls
- Regular access reviews conducted quarterly for Confidential data
- Processing restricted to authorized systems and personnel

#### **6.3. Data Retention & Archival**

- Classified data retained per retention schedules (Confidential: 7+ years, Restricted: 3-7 years, Internal/Public: per business need)
- Archived data maintains same classification level as original
- Backup systems provide equivalent protection to live data
- Archival requests documented with approval



#### **\*\*6.4. Data Deletion & Destruction\*\***

- Deletion/destruction conducted per data retention policy schedules
- **\*\*Confidential data:\*\*** Securely destroyed (crypto-erasure, secure wipe, or physical destruction for media)
- **\*\*Restricted data:\*\*** Standard secure deletion (secure wipe or deletion)
- **\*\*Internal/Public data:\*\*** Standard deletion
- Destruction documented and retained with certificates of destruction

#### **\*\*7. Special Data Categories\*\***

### **7. Special Data Categories**

#### **\*\*7.1. Personal Data (GDPR/CCPA Scope)\*\***

Personal data processed under GDPR or CCPA shall be classified at least as **\*\*Restricted\*\*** and implement additional controls:

- Data Processing Agreements (DPA) with processors
- Data subject rights (access, deletion, portability)
- Right to be forgotten procedures
- Breach notification procedures (72 hours to authorities)

#### **\*\*7.2. Encryption Keys & Passphrases\*\***

Cryptographic material shall be classified as **\*\*Confidential\*\***:

- Stored in approved key management systems (Azure Key Vault, etc.)
- Access strictly limited to systems requiring decryption
- Key rotation: Per NIST guidelines (annual minimum)
- Destruction: Cryptographic erasure upon end-of-life

#### **\*\*7.3. Payment Card Industry (PCI) Data\*\***

If processed, shall be classified as **\*\*Confidential\*\***:

- PCI DSS compliance required (Annual Audit + Attestation)
- Segmented networks from other systems
- Point-to-Point Encryption (P2PE) or tokenization mandatory
- Stored in PCI-compliant environments only

#### **\*\*8. Training & Awareness\*\***

### **8. Training & Awareness**

- All new employees receive data classification training during onboarding
- Annual refresher training required for all staff
- Department-specific training for data handlers and custodians
- Training completion tracked and documented

#### **\*\*9. Compliance & Monitoring\*\***

### **9. Compliance & Monitoring**

#### **\*\*9.1. Auditing\*\***

- Quarterly reviews of data classifications for accuracy
- Annual audit of data handling compliance with classification levels
- Unclassified data discovery scans (content classification tools)
- Access log reviews for unauthorized access attempts

#### **\*\*9.2. Incidents & Violations\*\***

Data classification violations shall be treated as potential security incidents:

- Reported per IS-CIRQ-P-014-G: Information Security Incident Management Policy
- Investigated for root cause and impact assessment
- Remediation documented and tracked

#### **\*\*9.3. Compliance Verification\*\***

- Data owner certification (annual) that classifications remain accurate
- Compliance reports on data handling adherence to classification standards
- Audit evidence maintained per IS-CIRQ-P-006-G (retention policy)

#### \*\*10. Responsibilities\*\*

### 10. Responsibilities

| \*\*Role\*\* | \*\*Responsibility\*\* |

|---|---|

| \*\*Executive Committee\*\* | Strategic approval of classification framework; oversight of compliance |

| \*\*IT Manager\*\* | Administer classification system; manage tools and infrastructure; coordinate audits |

| \*\*Data Owners\*\* | Classify data; approve access; certify compliance annually |

| \*\*Data Custodians\*\* | Implement controls per classification; handle requests; report incidents |

| \*\*Employees & Contractors\*\* | Handle data per classification; report misuse; complete training |

| \*\*Compliance\*\* | Audit classification compliance; report violations; recommend improvements |

#### \*\*11. Related Policies & Procedures\*\*

### 11. Related Policies & Procedures

This policy shall be read in conjunction with:

- IS-CIRQ-P-007-G: Asset Management Policy
- IS-CIRQ-P-008-G: Access Control Policy
- IS-CIRQ-P-009-G: Cryptography Policy
- IS-CIRQ-P-011-G: Operations Security Policy
- IS-CIRQ-P-014-G: Information Security Incident Management Policy
- IS-CIRQ-P-017-G/US/ASIA: Privacy Policy
- IS-CIRQ-PR-002-G: Data Handling & Media Management Procedure
- IS-CIRQ-PR-007-G: Data Retention & Disposal Procedure

#### \*\*12. Policy Review & Approval\*\*

12. Policy Review & Approval

| \*\*Role\*\* | \*\*Signature\*\* | \*\*Date\*\* |

---|---|---

| \*\*IT Manager\*\* | |

| \*\*Executive Committee\*\* | |

\*\*13. Document History\*\*

13. Document History

| \*\*Version\*\* | \*\*Effective Date\*\* | \*\*Description\*\* |

---|---|---

| 1.0 | 2026-03-02 | Initial policy creation; alignment with SOC2 and ISO 27001 requirements |

---

\*\*Document Classification:\*\* Internal (Public Distribution Permitted)

\*\*Distribution:\*\* All Cirque Personnel, Contractors, Third Parties (with NDA)